Nmap cheat sheet

Page 1: the commands that cover about 80% of real work. Syntax: nmap [scan type] [options] <target>

Targets

`10.0.0.5`	single host
`10.0.0.1-254`	range
`10.0.0.0/24`	whole subnet
`example.com`	domain
`-iL hosts.txt`	targets from file
`--exclude 10.0.0.1`	skip a host
`-6`	IPv6

Ports

`-p 80,443`	specific ports
`-p 1-1024`	range
`-p-`	all 65535 ports
`-F`	fast: top 100
`--top-ports 1000`	top N (1000 = default)
`-p U:53,T:80`	mix UDP and TCP
`--open`	show open only

Host discovery

`-sn`	ping sweep, no port scan
`-Pn`	skip ping: host blocks it
`-PR`	ARP ping (same LAN)
`-PS22,80`	TCP SYN ping
`-n`	no DNS lookups

Scan type

`-sS`	SYN, default as root
`-sT`	connect, no root needed
`-sU`	UDP (slow, scan top ports)
`-sA`	ACK: map firewall rules
`-sN / -sF / -sX`	stealth flag scans

Detection

`-sV`	service + version
`-O`	OS guess (root)
`-A`	-sV -O -sC traceroute
`-sV --version-light`	faster, less sure
`--traceroute`	path to target

NSE scripts

`-sC`	default safe scripts
`--script vuln`	known vulnerabilities
`--script "http-*"`	wildcard group
`--script banner`	single script
`--script-help NAME`	read docs
`--script-updatedb`	refresh index
`--script-args k=v`	pass arguments

Timing

-T0 / -T1 = IDS evasion

`-T2`	polite, light load
`-T3`	normal (default)
`-T4`	fast, good networks
`-T5`	insane: misses ports
`--min-rate 1000`	packets per sec floor
`--max-retries 1`	fewer retransmits
`--host-timeout 5m`	abandon slow host

Output

`-oA name`	all 3 formats (use it)
`-oN / -oX / -oG`	text / XML / grep
`-v / -vv`	verbose
`--reason`	why this state
`--packet-trace`	show packets
`--resume file`	continue scan
`ndiff a.xml b.xml`	compare scans

Evasion (own lab only)

`-f`	fragment packets
`-D RND:5,ME`	decoy IPs
`-g 53`	fixed source port
`--data-length 50`	pad packets
`--spoof-mac 0`	random MAC

Typical workflow: three passes

copy, replace TARGET

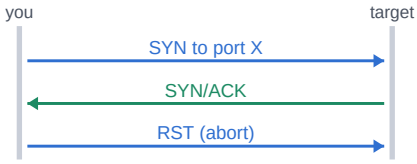
1 Who is up	`nmap -sn 10.0.0.0/24 -oA hosts`
2 All ports, fast	`nmap -p- --min-rate 1000 -T4 TARGET -oA ports`
3 Dig into open ports	`sudo nmap -sV -sC -O -p 22,80,443 TARGET -oA deep`

Notes

Scans, packet by packet

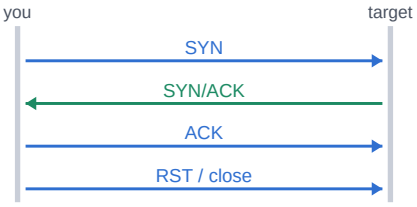
Page 2: what each scan sends, and how to read the reply.

TCP SYN `-sS`



SYN/ACK = open
RST = closed
silence = filtered

TCP connect `-sT`



handshake ok = open
RST = closed
no root needed, logged

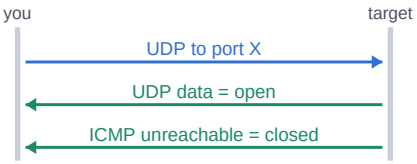
FIN / NULL / XMAS `-sF -sN -sX`

RST = closed
silence = open or dropped
unreliable on Windows

TCP ACK `-sA`

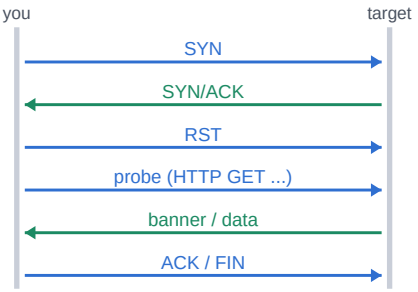
RST = not firewalled
silence = filtered
maps rules, not open ports

UDP `-sU`



reply = open
ICMP unreach = closed
silence = open|filtered

Version detect `-sV`



matches replies to
nmap-service-probes

Arrows: blue = you send green = target replies dashed = silence

Port states

`open`	service answered
`closed`	reachable, nothing listening
`filtered`	firewall dropping probes
`unfiltered`	reachable, state unknown (-sA)
`open|filtered`	no reply (UDP, FIN, NULL, XMAS)

Fixes when a scan acts up

`Everything filtered`	add -Pn
`Scan too slow`	-T4 --min-rate 1000
`UDP crawls`	--top-ports 50 -sU
`Missing ports`	lower rate, -T3, -p-
`No results as user`	use sudo (raw sockets)

Notes